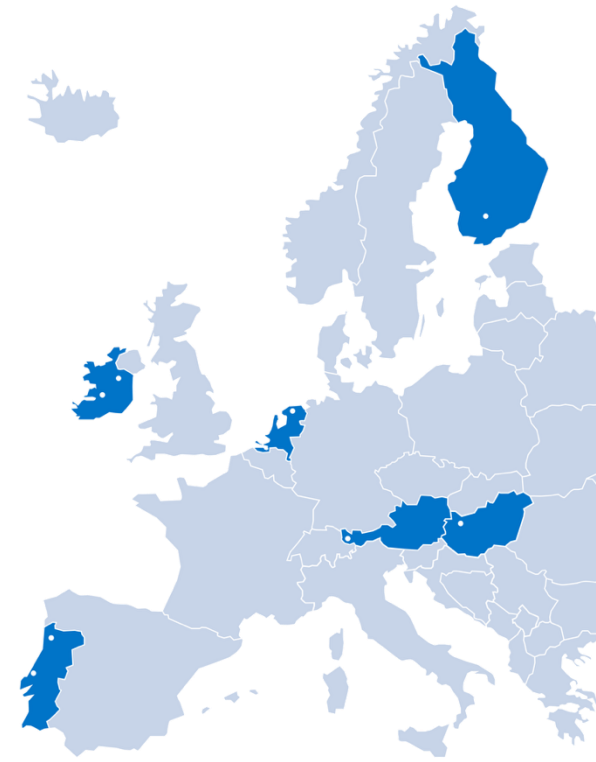


BASIC HACKING WITH KALI LINUX

SAP HACK YOUR DEVICE, 2025
ARMIN SIMMA
LEONEL SANTOS
JEROEN PIJPKER



Sources

- Fredrik Heiding, Emre Süren, Johannes Olegård, Robert Lagerström, “Penetration testing of connected households,” Computers & Security, Volume 126, 2023,
- A. Gupta, The IoT Hacker’s Handbook, 2019 https://doi.org/10.1007/978-1-4842-4300-8_2
- Fotios Chantzis: Practical IoT Hacking: The Definitive Guide to Attacking the Internet of Things, 2021
- Cisco course: skillsforall “Ethical Hacking”

Attribution

- These slides are based on the Cisco course: “Ethical Hacking”
- Thanks to Cisco!

Content

- Introduction to **Penetration Test** with focus on **IoT** devices
- methodology and tools
 - Footprinting
 - Scanning
 - Analysis of scanning results
 - Finding and exploiting vulnerabilities

Goals

- You know penetration testing
- You have learned the basics to perform a test yourself
- You know the methodology and tools used during a penetration test
- You know what information the tools can deliver

Tools



hping



Security Testing (3)

- One prominent type of security test is a **penetration test**
 - Analyses an IT-environment and searches for exploitable vulnerabilities
 - It „simulates“ the behavior of an attacker
 - The effort spent is an indication of the effort an attacker would have to spend to achieve the same result (i.e. to uncover vulnerabilities)
- **Phases of a penetration test**
 1. **Preparation phase**
 - define scope (not discussed here)
 2. **Footprinting**
 - collecting relevant information about the target environment
 3. **Scanning**
 - Examine the target networks and hosts in more detail
 4. **Analysis of scanning results**
 - Identify the systems that one will attempt to compromise during the following phase
 5. **Finding and exploiting vulnerabilities**
 - Identify vulnerable systems and demonstrate proof-of-concept or „real“ exploits
 6. **Reporting**
 - Prepare a written report and an oral presentation (not discussed here), including concrete recommendations

For this BIP (IoT-specific/ smart plug), footprinting is not so important -> only quick intro.

Footprinting and tools

Footprinting = **collecting relevant information** of the target and generating a profile of the target's Internet presence

The necessary **activities** depend on how much information is already available

- One extreme: starting with a company name only
- Other extreme: having detailed information about the systems

What information are we interested in?

Domain names, IP address blocks, contact persons

Interesting systems (hostnames, IP addresses), internal system configurations

Footprinting and tools

Domain names: google, whois

IP range: nslookup, dig ; entering IP at <http://www.ripe.net>

Technical contact persons: social media

Performing Active Reconnaissance:

Scanning

Nmap, Nessus, OpenVAS...

Terms

- Active Reconnaissance or
- Scanning
 - Port Scanning
 - Vulnerability Scanning

Performing Active Reconnaissance

Port Scanning

- port scan:
 - Enumerate running systems (“ping”)
 - enumerate the **services** that are running on the target
 - Find out version of each service
 - Find out which operating system is running

Performing Active Reconnaissance

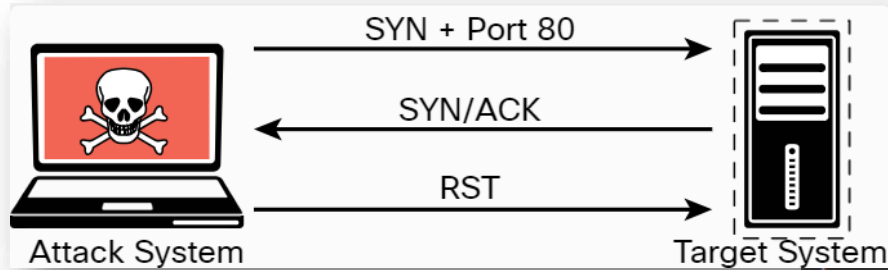
Overview (Cont.)

- A **port scan**: active scan
- the scanning tool sends various types of probes to the target
- examines the responses to determine whether the service is listening.
- **Nmap SYN scan**, TCP SYN packet sent o the TCP port it is probing.
- “half-open scanning” because does not open a full TCP connection.
- If response is a SYN/ACK -> port is in a listening state.
- If response is RST (reset) -> port is closed or is not in a listening state.
- If no response -> “filtered” because nmap cannot determine if the port is open or closed.

Nmap Port Status Reported	Response from Target	Nmap Analysis
Open	TCP SYN-ACK	The service is listening on the port.
Closed	TCP RST	The service is not listening on the port.
Filtered	No response from target or ICMP destination unreachable	The port is firewalled.

Performing Active Reconnaissance

Nmap SYN scan



- `nmap -sS target`

```
root@websploit]--[~]
#nmap -sS 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org )
Nmap scan report for 192.168.88.251
Host is up (0.00011s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
8888/tcp  open  sun-answerbook
9000/tcp  open  cslistener
9090/tcp  open  zeus-admin
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
```

Performing Active Reconnaissance

Nmap Scan Types

- common Nmap scanning options :
 - TCP Connect Scan (**-sT**)
 - UDP Scan (**-sU**)
 - TCP FIN Scan (**-sF**)
 - Host Discovery Scan (**-sn**)
 - Timing Options (**-T 0-5**)

TCP Connect Scan (-sT)

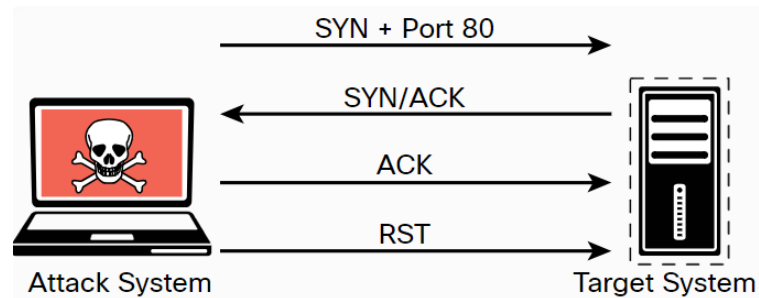
- makes use of the underlying operating system's mechanism to establish a full TCP connection
- Default if nmap used by non-root user
- creates more traffic than half-open scan

TCP Connect Scan (-sT) (Cont.)

Nmap Port Status Reported	Response from Target	Nmap Analysis
Open	TCP SYN-ACK	The service is listening on the port.
Closed	TCP RST	The service is not listening on the port.
Filtered	No response from target	The port is firewalled.

TCP Connect Scan (-sT)

- makes use of the underlying operating system’s mechanism to establish a full TCP connection
- Default if nmap used by non-root user
- creates more traffic than half-open scan



TCP Connect Scan (-sT) (Cont.)

- full TCP connect scan vs. half-open scan:
- increases amount of noise on the network -> may trigger alarms.

```
|--[root@websploit]--[~]
|--- #nmap -sT 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 12:48 EDT
Nmap scan report for 192.168.88.251
Host is up (0.00024s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
8888/tcp  open  sun-answerbook
9000/tcp  open  cslistener
9090/tcp  open  zeus-admin
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds
```

Performing Active Reconnaissance

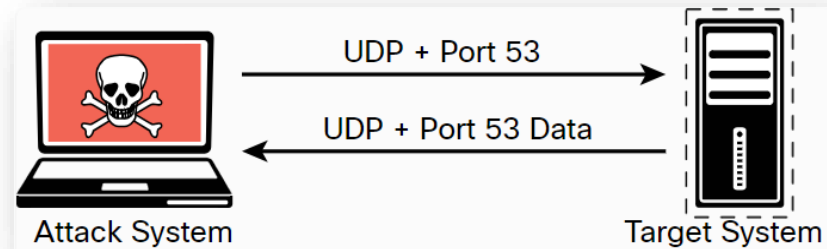
Nmap Scan Types (Cont.)

UDP Scan (-sU)

- E.g. when trying to enumerate a DNS, SNMP, or DHCP server.
 - all use UDP
- If response is: ICMP port unreachable -> port is marked as closed.
- If no response -> port marked as open/filtered.

Nmap Port Status Reported	Response from Target	Nmap Analysis
Open	Data returned from port	The service is listening on the port.
Closed	ICMP error message received	The service is not listening on the port.
Open/filtered	No ICMP response from target	The port is firewalled or timed out.

UDP Scan (-sU) (Cont.)



```
--[root@websploit]--[~]
--- # nmap -sU -p 53 192.168.88.251
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 13:12 EDT
Nmap scan report for 192.168.88.251
Host is up (0.00057s latency).
PORT      STATE SERVICE
53/udp    open  domain
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
```

Host Discovery Scan (-sn)

- uses different types of **ICMP** messages
- determines whether a host is online
- sometimes referred to as *ping sweep*.

```
--[root@websploit]--[~]
---- #nmap -sn 192.168.88.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2021-06-21 14:32 EDT
Nmap scan report for 192.168.88.1
Host is up (0.00045s latency).
MAC Address: E0:55:3D:E9:61:74 (Cisco Meraki)
Nmap scan report for 192.168.88.12
Host is up (0.00094s latency).
MAC Address: 0E:64:AF:27:9C:44 (Unknown)
Nmap scan report for 192.168.88.14
Host is up (0.0092s latency).
MAC Address: 00:B8:B3:FD:BF:C2 (Cisco Systems)
Nmap scan report for 192.168.88.24
Host is up (0.0033s latency).
MAC Address: 00:E1:6D:E5:43:C2 (Cisco Systems)
Nmap scan report for 192.168.88.32
Host is up (0.00046s latency).
MAC Address: 8E:38:F5:2D:6C:C0 (Unknown)
Nmap scan report for 192.168.88.231
Host is up (0.00061s latency).
MAC Address: FE:82:8C:A3:D2:3C (Unknown)
Nmap scan report for 192.168.88.251
Host is up (0.00040s latency).
MAC Address: 1E:BD:4F:AA:C6:BA (Unknown)
Nmap scan report for 192.168.88.71
Host is up.
Nmap scan report for 192.168.88.225
Host is up.
Nmap done: 256 IP addresses (11 hosts up) scanned in 2.45 seconds
--[root@websploit]--[~]
--- #
```

Timing Options (-T 0-5)

- The Nmap scanner provides six timing templates that can be specified with the -T option and the template number (0 through 5) or name.
- Nmap timing templates enable you to dictate how aggressive a scan will be, while leaving Nmap to pick the exact timing values.
- These are the timing options:
 - **-T0** (Paranoid) : Very slow, used for IDS evasion
 - **-T1** (Sneaky) : Quite slow, used for IDS evasion
 - **-T2** (Polite) : Slows down to consume less bandwidth, runs about 10 times slower than the default
 - **-T3** (Normal) : Default, a dynamic timing model based on target responsiveness
 - **-T4** (Aggressive) : Assumes a fast and reliable network and may overwhelm targets
 - **-T5** (Insane) : Very aggressive; will likely overwhelm targets or miss open ports

Performing Active Reconnaissance

Nmap flags

- nmap can be used to detect:
 - operating system (OS) and the
 - installed services
 - Including the software versions
- How: by looking for banners, TCP sequence number analysis etc.
- Flags: `-O` and `-sV` options (or `-A`, which combines both)

Performing Active Reconnaissance

Nmap further options/ flags

-p: specify the port ranges or individual ports

```
nmap -p 1-1000 <target>
```

-A (Aggressive scan): comprehensive probing including OS detection, service version detection, and traceroute.

-O (OS detection): Attempts to identify the target's operating system.

-T (Timing options): Allows adjusting the scan speed, with higher settings being faster but also more conspicuous.

--script (Scripting engine NSE): Enables running scripts for advanced scanning capabilities such as security checks and vulnerability detection.

```
nmap --script http-vuln* <target>
```

- Run a script to detect vulnerabilities related to HTTP on a target machine.

Performing Active Reconnaissance

Nmap Web page Enumeration

- Many Smart Devices use or run a web server
- After identifying that a web server is running on a target host,
- -> next step is scan web application
- map out the attack surface performing **web page enumeration** /or **web application enumeration**.
- brute forcing the directory and file paths of web applications
- probes the server for with a list of known files and directories used by common web applications

```
nmap -sV --script=http-enum <target>
```

- highlighted output shows : version of the web server (Nginx 1.17.2)
- several enumerated directories/folders.

```
--[root@websploit]--[~]
--- #nmap -sV --script=http-enum -p 80 192.168.88.251
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-22 11:53 EDT
Nmap scan report for 192.168.88.251
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx 1.17.2
| http-enum:
|   /admin/: Possible admin folder
|   /admin/index.html: Possible admin folder
|_  /s/: Potentially interesting folder
|_ http-server-header: nginx/1.17.2
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.54 seconds
--[root@websploit]--[~]
--- #
```

Performing Active Reconnaissance

Web page Enumeration

- Nikto is another web server enumeration tool.
- It's not as robust as the commercial web vulnerability scanners
- Because of the speed at which Nikto works to scan a web server, it is very noisy.
- It provides several options,
 - Including: authenticate to a web application that requires a username and password.

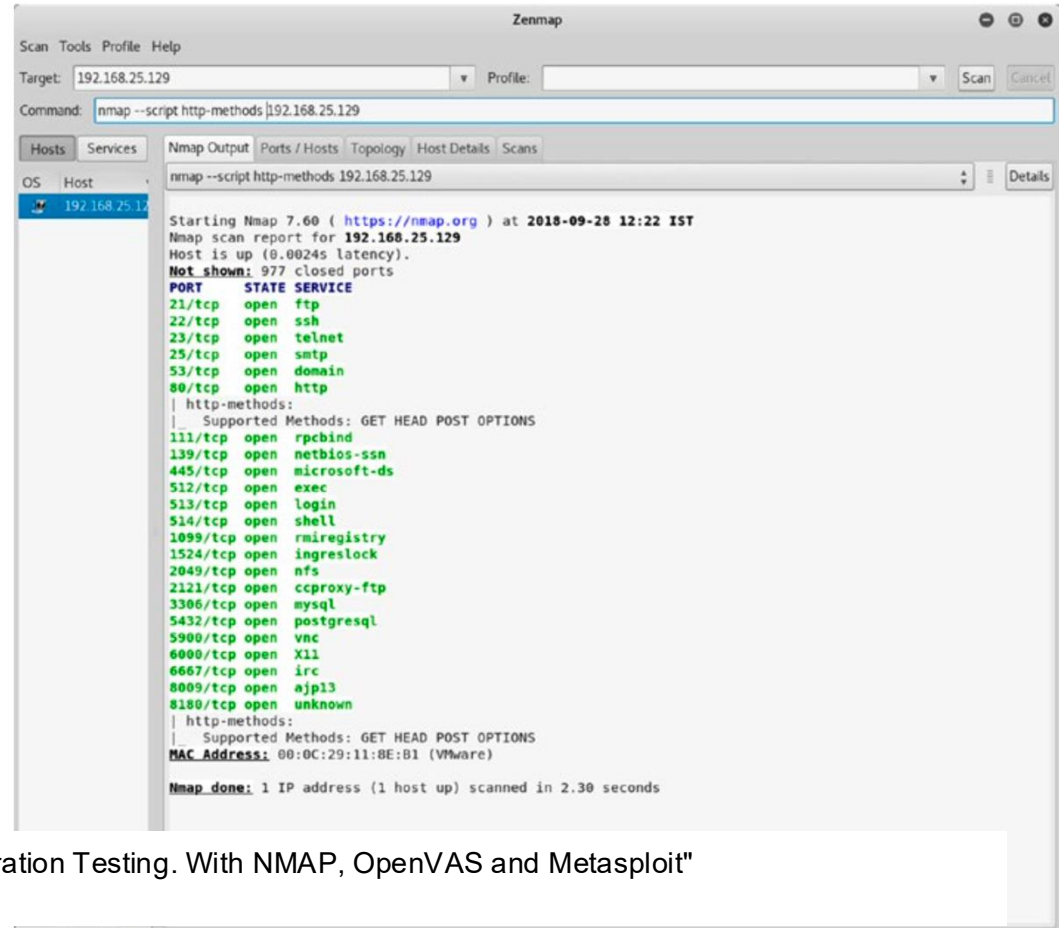
```
--[root@webexploit]--[~]
|--- #nikto -h 192.168.88.251
- Nikto v2.1.6

-----
+ Target IP:          192.168.88.251
+ Target Hostname:    192.168.88.251
+ Target Port:        80
-----
+ Server: nginx/1.17.2
+ The anti-clickjacking X-Frame-Options header is not present.
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to
the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the
user agent to render the content of the site in a different fashion
to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible
dirs)
+ OSVDB-3092: /admin/: This might be interesting...
+ /admin/index.html: Admin login page/section found.
+ /wp-admin/: Admin login page/section found.
+ /wp-login/: Admin login page/section found.
+ 7916 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:          2021-06-22 11:57:59 (GMT-4) (15 seconds)
-----
+ 1 host(s) tested
--[root@webexploit]--[~]
|--- #
```

Performing Active Reconnaissance

Nmap: HTTP methods

- HTTP supports the use of various methods such as GET, POST, DELETE...
- Sometimes these methods are left open on the web server unnecessarily.
- **NMAP script http-methods** enumerates HTTP methods.



Source: Sagar Rahalkar: "Quick Start Guide to Penetration Testing. With NMAP, OpenVAS and Metasploit"

Performing Active Reconnaissance

Nmap: HTTP

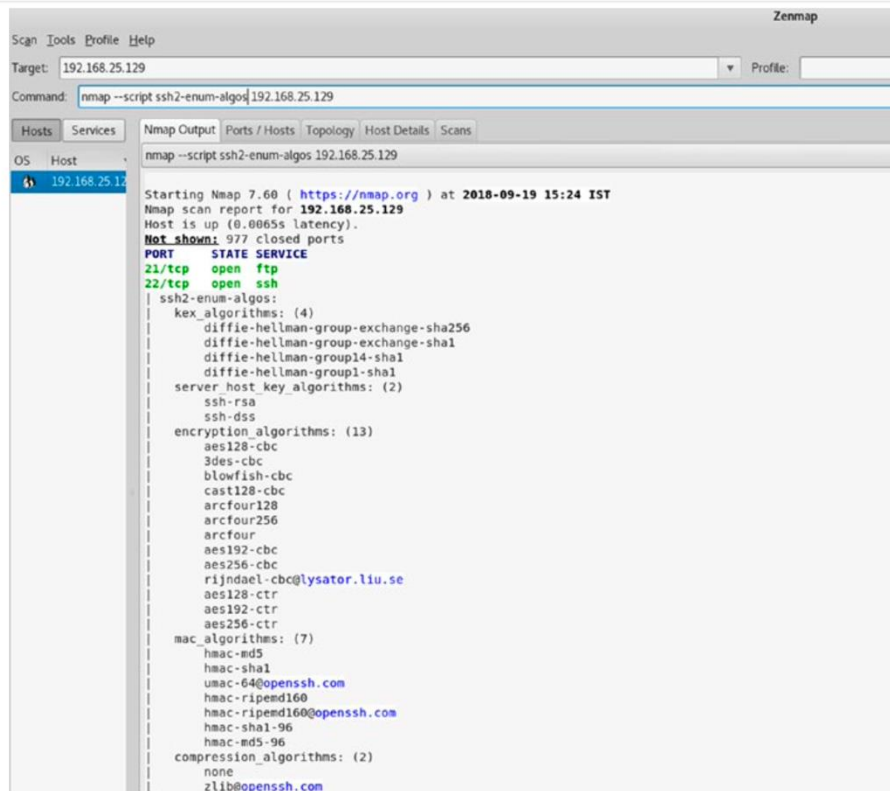
additional NMAP scripts for HTTP enumeration:

- http-title
- http-method-tamper
- http-trace
- http-fetch
- http-wordpress-enum
- http-devframework
- http NSE Library

Performing Active Reconnaissance

Nmap: ssh

- Some Smart Devices allow secure shell connection (remote logins) (ssh)
- NMAP script for enumerating the SSH service: **ssh2-enum-algos** script.
- lists the different encryption algorithms supported by the target SSH server.



```
Scan Tools Profile Help
Target: 192.168.25.129
Command: nmap --script ssh2-enum-algos 192.168.25.129

Hosts Services
Nmap Output Ports / Hosts Topology Host Details Scans
OS Host
192.168.25.129

Starting Nmap 7.60 ( https://nmap.org ) at 2018-09-19 15:24 IST
Nmap scan report for 192.168.25.129
Host is up (0.0065s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
|
| ssh2-enum-algos:
| | kex_algorithms: (4)
| | | diffie-hellman-group-exchange-sha256
| | | diffie-hellman-group-exchange-sha1
| | | diffie-hellman-group14-sha1
| | | diffie-hellman-group1-sha1
| | server_host_key_algorithms: (2)
| | | ssh-rsa
| | | ssh-dss
| | encryption_algorithms: (13)
| | | aes128-cbc
| | | 3des-cbc
| | | blowfish-cbc
| | | cast128-cbc
| | | arcfour128
| | | arcfour256
| | | arcfour
| | | aes192-cbc
| | | aes256-cbc
| | | rijndael-cbc@lysator.liu.se
| | | aes128-ctr
| | | aes192-ctr
| | | aes256-ctr
| | mac_algorithms: (7)
| | | hmac-md5
| | | | hmac-sha1
| | | | umac-64@openssh.com
| | | | hmac-ripemd160
| | | | hmac-ripemd160@openssh.com
| | | | hmac-sha1-96
| | | | hmac-md5-96
| | compression_algorithms: (2)
| | | none
| | | zlib@openssh.com
```

Source: Sagar Rahalkar: "Quick Start Guide to Penetration Testing. With NMAP, OpenVAS and Metasploit"

Performing Active Reconnaissance

Scanning – Manual Banner Grabbing

Manual methods: also well suited to determine software versions

By, e.g. using **telnet**, **netcat** or **openssl** (for SSL/TLS)

```
root@debian:~# telnet www.fhv.at 80
Trying 193.170.2.230...
Connected to web.uciv.net.
Escape character is '^]'.
GET / HTTP/1.0

HTTP/1.1 302 Found
Date: Wed, 15 Feb 2012 13:47:59 GMT
Server: Apache/2.2.21 (FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2
Location: http://www.fhv.at/
Content-Length: 317
Connection: close
Content-Type: text/html; charset=iso-8859-1
```

```
root@debian:~# openssl s_client -connect www.fhv.at:443_
GET / HTTP/1.0

HTTP/1.1 401 Unauthorized
Date: Wed, 15 Feb 2012 13:53:29 GMT
Server: Zope/(Zope 2.9.4-final, python 2.4.3, linux2) ZServer/1.1
Bobo-Exception-Line: 687
Content-Length: 268
Bobo-Exception-Value: See the server error log for details
Content-Type: text/html; charset=iso-8859-15
Bobo-Exception-Type: Unauthorized
Bobo-Exception-File: HTTPResponse.py
WWW-Authenticate: basic realm="FHV-Campus"
Connection: close
```

Vulnerability Scanners go further

- They first also perform port scans and try to detect software versions

- In addition, they contain a large **database of known vulnerabilities** of specific software versions and can therefore help to interpret the results

- They also attempt to **automatically exploit some vulnerabilities** (e.g. try default passwords)

Vulnerabilities Scanners are **powerful tools**, but

- Their database of known vulnerabilities must be **constantly updated**

- Often produce **false positives** (e.g. identifying the wrong software version and drawing wrong conclusions)

- The result therefore still require manual interpretation and verification

- They are usually limited to detecting publicly known vulnerabilities and misconfigurations

Performing Active Reconnaissance

Scanning – Vulnerability Scanning

- Can be done using nmap with the “vulners” script
`nmap -sV --script vulners <target>`
- output shows potential CVE and exploit suggestion.
- Can complement the searches directly on “vulners.com”.

Performing Active Reconnaissance

Scanning – Vulnerability Scanning

- Analysis of results
- quick indication of CVEs and searching for CVE vulnerabilities on “[CVEdetails.com](https://cvedetails.com)”
- search for exploits on the web and on sites such as “exploit-db.com”

Scanning – Vulnerability Scanning

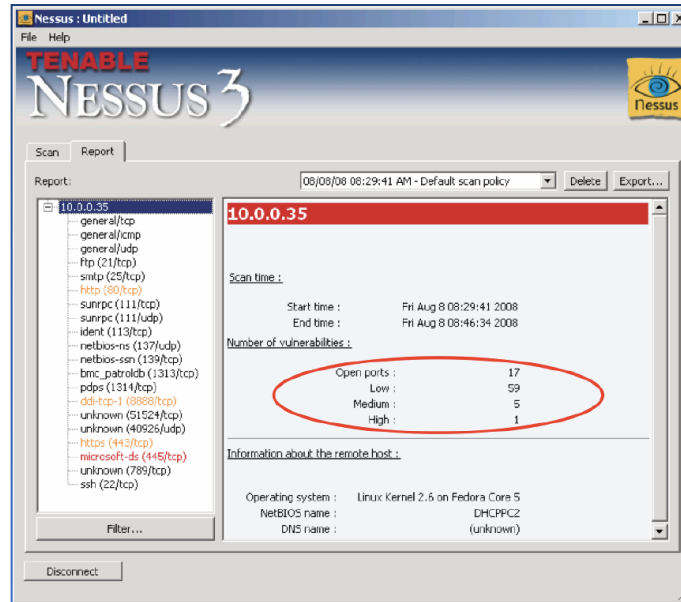
- The most popular general vulnerability scanner is **Nessus**
 - "General" in the sense that it tests at a **wide range of layers**
 - From OS vulnerabilities to server application vulnerabilities
- The vulnerability tests in Nessus are called **plugins**
 - There are more than **10'000 official plugins** (distributed with Nessus) available
 - It's also possible to write own plugins
 - Nessus can be configured to **auto-update** its plugins over the internet
- There's a trend toward **commercialization**
 - Maintained by **Tenable Network Security**
 - Was originally free and open source
 - The free version can only be used to scan own systems (e.g. at home) but not to offer commercial services

Scanning – Vulnerability Scanning

- Nessus is a **client/server application**
 - Both components are available for a wide range of OS
- The **actual scanner is the server** and is reached through TCP port 1241
 - **Accounts** (username/password) for client-users must be set up on the server
 - It is possible to connect through SSL/TLS, so the Nessus server can securely be used from anywhere
- **Clients connect to the server** and configure and initiate scans
 - Usually, **graphical mode** is used but command-line is also available
 - Allows to define which plugins to use in a fine-granular way
 - Present results and generate reports for further analysis

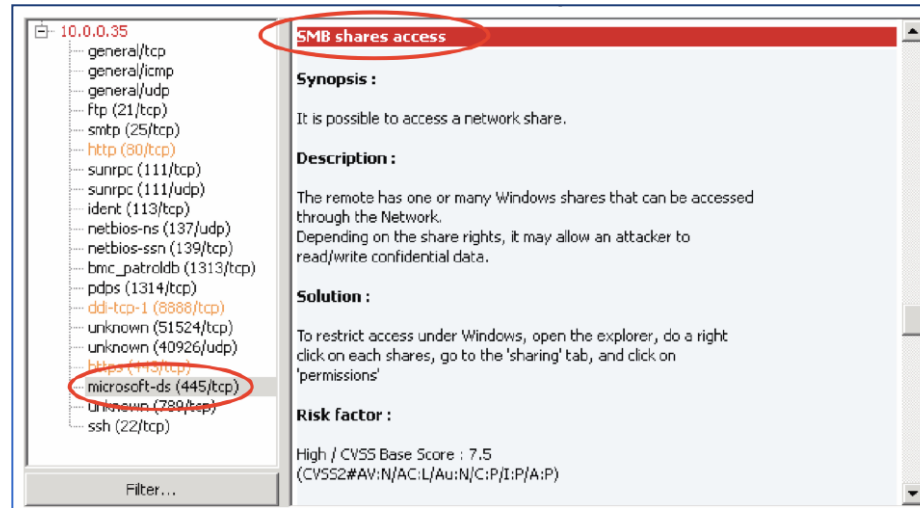
Scanning – Vulnerability Scanning

- A **full Nessus scan** (all Plugins are enabled) of a not specifically hardened Linux host



Scanning – Vulnerability Scanning

- Nessus provides detailed information about the problems detected
- High risk example



- Note: for Nessus, this is a high risk, but it may be a false positive
 - If one accidentally allows share access, it is indeed a high risk
 - If share access is purposely allowed, it's a false positive

Scanning – Vulnerability Scanning

- Medium risk example

netbios-ns (137/udp)
netbios-ssn (139/tcp)
bmc_patrolldb (1313/tcp)
ndps (1314/tcp)
ddi-tcp-1 (8888/tcp)
unknown (51521/tcp)
unknown (40926/udp)
https (443/tcp)
microsoft-ds (445/tcp)
unknown (789/tcp)

Weak Supported SSL Ciphers Suites

Synopsis :

The remote service supports the use of weak SSL ciphers.

Description :

The remote host supports the use of SSL ciphers that offer either weak encryption or no encryption at all.

- In this case, this is a **true positive** as ciphers with 40-bit keys are supported
- Medium risk is a **reasonable classification** because it is not something an attacker can easily exploit

Plugin output :

Here is the list of weak SSL ciphers supported by the remote server :

Low Strength Ciphers (< 56-bit key)

SSLv3
EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES(40) Mac=SHA1 export
EXP-DES-CBC-SHA Kx=RSA(512) Au=RSA Enc=DES(40) Mac=SHA1 export
EXP-RC4-MD5 Kx=RSA(512) Au=RSA Enc=RC4(40) Mac=MD5 export
TLSv1
EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES(40) Mac=SHA1 export
EXP-DES-CBC-SHA Kx=RSA(512) Au=RSA Enc=DES(40) Mac=SHA1 export
EXP-RC4-MD5 Kx=RSA(512) Au=RSA Enc=RC4(40) Mac=MD5 export

The fields above are :

{OpenSSL ciphername}
Kx={key exchange}
Au={authentication}
Enc={symmetric encryption method}
Mac={message authentication code}
{export flag}

Scanning – Vulnerability Scanning

- A free, open source alternative to Nessus: **OpenVAS**
 - Provides very similar results to Nessus
 - **OpenVAS** is the scanner component **Greenbone Vulnerability Management** (GVM)

Scanning – Vulnerability Scanning

The screenshot displays the Greenbone Security Assistant (GSA) web interface. The browser address bar shows the URL `https://127.0.0.1:9392/report/e365e005-006a-44bc-8ec2-b08590293478`. The interface includes a navigation bar with tabs for Dashboards, Scans, Assets, Resilience, SecInfo, Configuration, Administration, and Help. The main content area shows a report for a scan completed on Monday, February 10, 2025, at 7:24 AM UTC. The report ID is `e365e005-006a-44bc-8ec2-b08590293478`. The scan results are categorized by Information, Results (5 of 102), Hosts (1 of 1), Ports (1 of 6), Applications (0 of 0), Operating Systems (0 of 0), CVEs (2 of 2), Closed CVEs (0 of 0), TLS Certificates (0 of 0), Error Messages (0 of 0), and User Tags (0). The Vulnerability section lists five findings:

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Operating System (OS) End of Life (EOL) Detection	10.0 (High)	80 %	10.6.6.23	gravemind.vm	general/tcp	Mon, Feb 10, 2025 7:35 AM UTC
Anonymous FTP Login Reporting	6.4 (Medium)	80 %	10.6.6.23	gravemind.vm	21/tcp	Mon, Feb 10, 2025 7:34 AM UTC
FTP Unencrypted Cleartext Login	4.9 (Medium)	70 %	10.6.6.23	gravemind.vm	21/tcp	Mon, Feb 10, 2025 7:34 AM UTC
TCP Timestamps Information Disclosure	2.6 (Low)	80 %	10.6.6.23	gravemind.vm	general/tcp	Mon, Feb 10, 2025 7:35 AM UTC
ICMP Timestamp Reply Information Disclosure	2.1 (Low)	80 %	10.6.6.23	gravemind.vm	general/icmp	Mon, Feb 10, 2025 7:34 AM UTC

(Applied filter: apply_overrides=0 levels=hml rows=100 min_qod=70 first=1 sort=reverse=severity)

Greenbone Vulnerability Management (GVM)

Scanning – Vulnerability Scanning

OpenVAS

The screenshot displays the OpenVAS-Client window. The title bar reads "OpenVAS-Client". The menu bar includes "File", "View", "Task", "Scope", "Report", "Extras", and "Help". The sidebar on the left shows a tree view of the scan process, with "Report 20110303-1" selected. The main pane is divided into two sections. The top section, titled "Report for scope: Scanner: Octopus (Task: Scan of Octopus)", contains a table with columns "Name", "High", "Medium", and "Low". The table lists various scans, with "Report 20110303-1" circled in red, showing 3 High, 11 Medium, and 42 Low severity issues. The bottom section, titled "Host/Port/Severity", lists the scanned host "10.0.1.2" and its ports. The "Weak Ciphers" vulnerability is highlighted with a red circle. The detailed view on the right shows the vulnerability description: "Server will not supports SSLv2 Ciphers. Server supports SSLv3 ciphers. Server supports TLSv1 ciphers. Weak Ciphers". The "Weak Ciphers" section lists the following ciphers: SSL3_RSA_RC4_40_MD5 : SSL_EXPORT, SSL3_RSA_DES_40_CBC_SHA : SSL_EXPORT, SSL3_EDH_RSA_DES_40_CBC_SHA : SSL_EXPORT, TLS1_RSA_RC4_40_MD5 : SSL_EXPORT, TLS1_RSA_DES_40_CBC_SHA : SSL_EXPORT, and TLS1_EDH_RSA_DES_40_CBC_SHA : SSL_EXPORT. The bottom status bar indicates the scan took place from Thu Mar 3 16:49:59 2011 to Thu Mar 3 17:01:45 2011.

Name	High	Medium	Low
Global Settings			
▼ Scan of Octopus			
▼ Scanner: Octopus			
Report 20110303-1	3	11	42
► Scanner: Localhost			
► Testscans			
► Datainherit			

Host/Port/Severity

- 10.0.1.2
 - microsoft-ds (445/tcp)
 - https (443/tcp)
 - http (80/tcp)
 - netbios-ns (137/udp)
 - domain (53/udp)
 - domain (53/tcp)
 - ssh (22/tcp)
 - smtp (25/tcp)
 - pop3s (995/tcp)
 - pop3 (110/tcp)
 - otp (9390/tcp)
 - ntp (123/udp)
 - netbios-ssn (139/tcp)
 - imaps (993/tcp)
 - general/tcp
 - ddi-tcp-1 (8888/tcp)

Security Note

Scan took place from Thu Mar 3 16:49:59 2011 to Thu Mar 3 17:01:45 2011

Scanning – Vulnerability Scanning

- further tools:
- <http://sectools.org/tag/vuln-scanners/>

Web Scanning Tools

- Burp
- Zed Attack Proxy ZAP
- Nikto
- W3AF
- SQLMap
- BeEF
- Dirb (content discovery)
- cURL
- Bettercap (not web but wireless, Bluetooth)

Scanning – Summary

- Scanning serves to analyze the network structure and the individual hosts in detail
- After scanning, you know the following information
 - Parts or all of the network structure
 - Hosts that are reachable from your location
- Of a subset of all hosts (or all hosts if the analyzed environment is small) you know more detailed information
 - Operating system
 - Available services (that are visible from your location)
 - Software versions of the services
 - Potential vulnerabilities that may be exploited

- If time permits: continue with ***Basic_Hacking_MITM_ettercap.pdf***